

The Business Information Security Officer (BISO) can be defined as a senior cybersecurity leadership position that acts in a more tactical sense while also being an operations-level employee to a variety of different business units. By working in this way they can enable the business by mitigating cybersecurity risks. The BISO position is meant to bridge the gap between security and business interests, with the BISO usually operating as the CISO's deputy and performing business strategy at a granular level. The BISO role can increase cybersecurity-business alignment which helps with business outcomes. However, from one perspective you can argue that today's CISOs should themselves have both the technical and business expertise to align security and business objectives without requiring the input of a specialized business-oriented officer.

The incident in question involves the Simpton Corp. and they suffered a high-profile cybersecurity breach in mid-2020 that compromised all Fit88 devices and the wearable chest straps. To combat future intrusions, Simpton hired a Chief Information Security Officer (CISO) with five full-time staff dedicated to a focused security program. The company is questioning do they also need to hire one or more BISOs in specific geographies to address potential upcoming challenges related to the cybersecurity incident. The establishment of a BISO might help mitigate/remediate issues by improving the security program's credibility by aligning security and business goals. However, there are possible negative impacts, such as creating further complexity since the titles are very similar in nature when pertaining to CISO/BISO.

Let's look at the potential benefits and drawbacks if Simpton should hire at least one BISO to work closely with the CISO and oversee strategy implementation at a granular level. The BISO should be located in the U.S. so that they can focus on the market that Simpton is targeting as it pertains to revenue. The BISO should act as an extension of the CISO but with more power than just a mere underling. That is because one of their primary concerns would be how to have mandates to raise the cybersecurity program's profile within the organization, increase delivery of cybersecurity services internally and connecting with business units. All of this while learning the needs of the company while offering them technical and operational support. Then finally taking all that information and organizing and executing cybersecurity quick and efficiently. By establishing a BISO, Simpton can improve cybersecurity-business alignment, increase the security program's credibility, and their security and business objectives will be able to withstand higher levels of scrutiny in case of another incident.

The BISO role can also provide Simpton Corp. a stronger dynamic between the security program and business objectives. This role would help the company stay prepared to face any new unknown cybersecurity challenges in the future. This is very important because Simpton is aiming to enter the lucrative American market to increase its revenue in the USA. The BISO in coordination with the CISO's tactical and operational-level to the business units and oversee strategy implementation at a granular level. Also, By implementing a BISO role, Simpton can be sure that the security program aligns with the company's objectives and can withstand increased scrutiny, especially since the European Union's General Data Protection Regulation (GDPR) may be imminent.

The negatives of adding a BISO role are mainly due with how roles are defined at higher levels. Titles becoming all-encompassing umbrellas when a problem arises and someone like a CISO could already be operating in a company exactly like a BISO would be in some functions, so it could be hard to tell the difference. Also, while a BISO may be highly ranked within the company most of their power is regulated or accessed through the CISO. This leads to a one point of failure/success in their role if they can't work together or come to a middle ground. BISO may also find themselves trying to comprise security functionality in the pursuit of certain critical business functions. How much risk is the BISO willing to assume for revenue/profit for the company or would there be a company defined policy that would dictate how much BISO should focus on impact of security vs impact on profit. And to wrap it up the cost of hiring A BISO or BISOs would be quite high since they both need a business background and a high enough security background to coordinate with the CISO. At the end of the day input can generate must better business decisions.

In conclusion, Simpton should establish at least one BISO role to enhance its security program and align it with the company's objectives. That is because while there may be some potential negative implications associated with creating this role, the benefits greatly outweigh the drawbacks. As cybersecurity threats continue to grow in complexity and frequency, businesses, especially ones like Simpton, must take the necessary steps to protect themselves. By establishing a BISO, Simpton can achieve this and strengthen its security posture, while ensuring that its cybersecurity program aligns with its business objectives. The BISO is a necessary step in ensuring a strong security posture for company and most importantly their customers.